

HACKER SPRINT / MANIPAL BENGALURU

RetireSafe

Preventing takeover risks during cloud-resource retirement

Problem definition, documented cases, existing protections, and the innovation opportunity.

RESEARCH DOSSIER | 01 OCTOBER 2026

When a resource disappears,
its old trust relationships can survive.

Evidence-led concept brief. Compiled from the research discussion; no product implementation or independent reproduction of the incidents is claimed.

RESEARCH BRIEF / 01

The problem in detail

Deleting infrastructure does not automatically revoke the trust placed in its address.

Organizations routinely retire cloud storage buckets, web applications, temporary websites, and third-party services. The underlying resource disappears, but DNS records, application URLs, software-update references, or authorization rules may remain.

If a released name or domain becomes available to another owner, an attacker may reclaim it. Surviving references can send users, applications, or automated systems to attacker-controlled infrastructure, sometimes under the original organization's legitimate domain. Microsoft documents this failure for deprovisioned Azure resources and dangling DNS records. [1]

Possible consequences include phishing, fraudulent content, malicious software distribution, and unauthorized receipt of information. Actual impact depends on the surviving reference and whether the consumer verifies ownership or content integrity.

THE COORDINATION GAP

Ownership and dependency information are spread across cloud accounts, DNS providers, repositories, deployed applications, and external consumers. A resource can appear unused to the team deleting it while remaining trusted elsewhere. A complete inventory of every external consumer may be impossible.

PRIMARY USER AND DECISION

User: a platform or cloud engineer reviewing a deletion or migration, supported by security.

Decision: what must be removed, migrated, or protected before the resource can be released?

RETIRESAFE'S CHALLENGE

Determine whether a resource can be safely retired, identify trust relationships that would survive deletion, and coordinate their removal or migration before ownership is released. Report evidence and uncertainty instead of an unqualified guarantee of safety.

READING GUIDE

Page	Topic
3	Failure sequence and conditions for exploitation
4-5	Reported malicious exploitation and academic evidence
6	Researcher demonstrations of real exposure
7	Existing protections and the remaining opportunity
8	Submission-ready statement and evidence boundaries
9	Source register with clickable links

SOURCE NOTES [1] | Full citations and links on page 9.

RESEARCH BRIEF / 02

How trust survives deletion

A fictional event website illustrates the lifecycle. This is an explanatory scenario, not an additional reported incident.

01 / CREATE	An organization creates a cloud application for an event.
02 / CONNECT	It points event.example.com to the application. Users and systems begin using that address.
03 / RETIRE	The application is deleted after the event, but the DNS reference remains.
04 / RECLAIM	Where the provider permits it, another owner claims the abandoned resource name.
05 / INHERIT	The surviving reference directs visitors to the replacement owner’s content.

The organization still owns its parent domain. The vulnerable connection is between that trusted name and a resource it no longer controls. A direct storage URL in an old application creates a related failure without a custom domain. [1, 6]

A BROKEN LINK IS NOT ENOUGH

Condition	Why it matters
Resource released	A different account must be able to obtain control.
Name reassignable	Reserved names and verification may prevent takeover.
Reference survives	DNS, application configuration, or authorization still points there.
Consumer remains	Someone or something continues relying on the reference.
Controls permit impact	Ownership or integrity checks do not reject the replacement.

Distinguish a stale reference from a reclaimable endpoint, and a reclaimable endpoint from a demonstrated security impact.
SOURCE NOTES [1] [6] | Full citations and links on page 9.

RESEARCH BRIEF / 03

Observed malicious takeovers

Named incidents and examples from the Hazy Hawk campaign. Dates describe reported activity or publication, not current vulnerability.

01 / CDC: abandoned Azure endpoint

Observed: February 2025. **Initial report:** 10 March 2025.

Infoblox investigated malicious links under ahbazuretestapp[.]cdc[.]gov. Its DNS alias pointed to an abandoned Azure application endpoint. A replacement owner used the CDC subdomain to direct visitors toward malicious content, including scams and scareware. This was observed abuse, not a researcher’s harmless demonstration. It does not establish a breach of the CDC’s internal network. [2]

Retirement of the application and retirement of its DNS reference needed to be coordinated.

02-04 / Additional Hazy Hawk cases

Infoblox’s 20 May 2025 investigation linked the CDC incident to Hazy Hawk, with activity traced to at least December 2023. [3]

Example	Reported observation
French government Olympics website November 2024	The site was taken down after the event, but its DNS record remained. The hijacked site redirected visitors through fake CAPTCHAs, notification prompts, and scams.
oercommons S3 bucket March 2025	Hazy Hawk hijacked the bucket and used its address in scam distribution.
Other organizational subdomains 2023-2025	The report names parent domains belonging to Deloitte, EY, PwC, UC Berkeley, UCL, Alabama’s government, and Australia’s health department. These are subdomain hijacks, not evidence of complete organizational compromise.

Table 1 of the original report lists additional affected parent domains. It is a historical observation list, not a list of currently vulnerable targets. Several examples here belong to the same campaign. [3]

RELEVANCE TO RETIRESAFE

Temporary event infrastructure and institutional services both need a retirement process that checks surviving references. A deletion event alone cannot establish that every consumer has withdrawn trust in the old endpoint.

SOURCE NOTES [2] [3] | Full citations and links on page 9.

RESEARCH BRIEF / 04

Email abuse and measured scale

05 / SubdoMailing

Disclosed: 26 February 2024. **Evidence:** observed malicious email campaign.

Guardio documented abandoned domains still referenced by legitimate organizations’ DNS and email configurations. Two examples illustrate different surviving relationships. [4]

Example	Surviving trust relationship
MSN promotional subdomain	marthastewart[.]msn[.]com pointed to a domain associated with a 2001 promotion. The destination was re-registered in September 2022. Guardio observed a deceptive email whose SPF check passed using the MSN subdomain.
Swatch email configuration	An SPF rule still authorized directtoaccess[.]com. Guardio reported that this abandoned domain had been reclaimed and its addresses used to expand the set of authorized email senders.

Guardio reported more than 8,000 affected domains and millions of malicious emails daily. These are vendor-reported figures. An SPF pass alone does not mean every other email-security check is defeated. [4]

DESIGN IMPLICATION

A future RetireSafe version could inspect authorization dependencies such as SPF records when a domain or service is retired. This extends beyond website routing and should not be assumed coverage of a bucket-only prototype.

06 / Peer-reviewed cloud-hijack research

Publication: NSDI 2024. **Evidence:** observed abuse across cloud platforms.

Finding	Interpretation
20,904 hijacked resources	Instances identified, not a count of breached organizations.
About one-third lasted over 65 days	Some hijacks persisted for substantial periods.
About 1,800 attacking infrastructures	Clusters identified from abuse resources and content.
75% blackhat SEO	Most observed abuse was search-engine manipulation. Authors also reported fraudulent certificates and stolen cookies.

The study establishes actual abuse at scale. Its count must not be presented as 20,904 ransomware attacks or unique victims. [5]

SOURCE NOTES [4] [5] | Full citations and links on page 9.

RESEARCH BRIEF / 05

Demonstrated exposure

These investigations showed real surviving dependencies. Present them as researcher demonstrations, not criminal breaches.

07 / Abandoned S3 buckets

Published: 4 February 2025. watchTowr reported registering about 150 abandoned S3 buckets and receiving more than 8 million HTTP requests over two months. [6]

Example	What continued to arrive
echochamberjs	Requests for a JavaScript file referenced by a web project.
Unnamed antivirus repository	Requests resembling Linux APT repository traffic. Those requests alone do not show that clients would accept an unsigned malicious package.
mozilla-games / Emscripten	Requests for an old executable. Documentation removed the bucket reference in March 2015, but traffic persisted. That date does not establish when the bucket was deleted.

The researchers demonstrated continued contact with reclaimed resources, not eight million infections or successful malicious updates on every requesting client. [6]

RETIRESAFE IMPLICATION

Updating documentation is insufficient evidence that deployed consumers have stopped using an old address. Observe runtime traffic and retain uncertainty about offline or infrequent clients.

08 / The expired .mobi WHOIS domain

Published: 11 September 2024. After the .mobi WHOIS service moved, its old domain expired. watchTowr registered it and reported 2.5 million queries from more than 135,000 unique systems. [7]

The researchers demonstrated that GlobalSign’s certificate-validation workflow accepted an email address supplied by their replacement WHOIS server as a validation option. They stopped before issuing a rogue certificate. The old endpoint was later directed to infrastructure proxying legitimate responses. [7]

This demonstration involved abandoned domain infrastructure, not S3. Moving a service does not automatically move the trust placed in its old endpoint. [7]

Observed traffic proves that a dependency survives. It does not, by itself, prove successful compromise.

SOURCE NOTES [6] [7] | Full citations and links on page 9.

RESEARCH BRIEF / 06

Existing protections

The vulnerability category is known. Providers already offer defenses, and RetireSafe must recognize them rather than label every stale reference exploitable.

Protection	Consequence for RetireSafe
S3 account regional namespaces Introduced March 2026	Other accounts cannot reclaim these bucket names. Legacy global buckets still require careful migration. Existing buckets cannot simply be renamed. [8]
S3 expected-owner checks	Supported operations reject a bucket owned by an unexpected AWS account. A surviving reference has a different risk profile when its consumer enforces this check. [9]
Azure protections	Dangling-DNS detection, supported alias records, and domain verification address parts of the problem. Evaluate which protection applies and whether it is configured. [1]
GitHub Pages verification	Verified custom domains receive takeover protection within the documented scope. An unused reference alone is not proof of exploitability. [10]
Infrastructure deletion guards	Terraform prevent_destroy rejects destructive plans while configured, but removing the resource configuration removes that protection. It is not an inventory of external consumers. [11]

THE REMAINING PRODUCT OPPORTUNITY

Coordinate retirement across provider protections, repositories, DNS, and observed traffic. Explain which dependencies remain, which are protected, which need migration, and which cannot be evaluated with the available evidence.

Useful outputs could include a blocked deletion with a precise reason, a proposed migration patch, a decision to retain a resource name, and an evidence record describing the inspection scope. These are proposed capabilities, not a validated implementation.

The innovation is a demonstrable improvement in safe retirement, not rediscovering subdomain takeover.

SOURCE NOTES [1] [8] [9] [10] [11] | Full citations and links on page 9.

RESEARCH BRIEF / 07

Submission-ready framing

PROJECT TITLE

RetireSafe: Preventing takeover risks during cloud-resource retirement

How can organizations retire cloud resources without leaving users and software trusting infrastructure they no longer control?

Cloud resources are frequently deleted while DNS records, application configurations, and automated consumers continue referencing them. Where resource names can be reclaimed, these surviving dependencies may transfer trusted traffic to an attacker.

Existing protections vary by provider and require correct configuration, while dependency information remains distributed across teams and systems. The challenge is to develop an evidence-driven retirement workflow that identifies surviving dependencies, evaluates whether they create takeover risk, and guides their removal or migration before a resource is released, without unnecessarily disrupting legitimate services.

A FOCUSED INITIAL SCOPE

For a hackathon, begin with legacy S3 buckets, a supplied repository, a DNS export, access logs, and a proposed infrastructure deletion. Show a controlled before-and-after retirement scenario. Broader email and domain cases explain future relevance, not initial coverage.

WHAT THE EVIDENCE ESTABLISHES

1. Malicious actors have exploited retired resources and forgotten references.
2. Dependencies include web routing, downloads, scripts, email authorization, and identity-related infrastructure.
3. Dependencies can outlive their projects by years.

WHAT IT DOES NOT ESTABLISH

Not every deleted resource is reclaimable. Not every stale reference is exploitable. A subdomain hijack does not prove an internal network breach. Request counts are not infection counts. Several examples belong to the same investigation and must not be counted as independent campaigns.

RECOMMENDED PITCH SEQUENCE

Lead with the CDC incident for a concrete victim example. Use the NSDI study for measured scale. Use the S3 investigation to explain why DNS-only inspection misses application dependencies. Then show an evidence-based retirement decision.

Scope: a curated collection of verified public reports, not an exhaustive registry of every case. Historical findings do not assert that named resources remain vulnerable today.

RESEARCH BRIEF / 08

Source register

Clickable primary reports, research, and provider documentation. Numbers match the brief. Research compiled for this discussion on 1 October 2026.

[01] Microsoft Learn

Prevent dangling DNS entries and avoid subdomain takeover - Open source

[02] Infoblox | 10 March 2025

CDC incident: How scammers hijack major brands - Open source

[03] Infoblox | 20 May 2025

Hazy Hawk investigation; Table 1 lists affected parent domains - Open source

[04] Guardio Labs | 26 February 2024

SubdoMailing: CNAME and SPF abuse, MSN and Swatch examples - Open source

[05] USENIX NSDI 2024 | Friess et al.

Cloudy with a Chance of Cyberattacks: Dangling Resources Abuse on Cloud Platforms - Open source

[06] watchTowr | 4 February 2025

8 Million Requests Later: abandoned S3 bucket investigation - Open source

[07] watchTowr | 11 September 2024

We Spent \$20 To Achieve RCE And Accidentally Became The Admins Of .MOBI - Open source

[08] AWS Storage Blog | 24 April 2026

Migrate to Amazon S3 account regional namespaces - Open source

[09] AWS documentation

Verifying bucket ownership with bucket owner condition - Open source

[10] GitHub documentation

Verifying your custom domain for GitHub Pages - Open source

[11] HashiCorp documentation

Terraform lifecycle meta-argument: prevent_destroy - Open source